Security Now! #1098 - 09-29-26

How worried should we be?

This week on Security Now!

- Muse has a bad 0-day • The regularity of "Irregular"
- More rogue OpenAI breaches • The Seven Deadly Sins (TSDS) hacker group
- Liquified Natural Gas (LNG) cargo ship hacked
- The FBI offended ShinyHunters's delicate sensibilities
- Canonical switches to an every–2-weeks release cadence
- Axios' AI 101: AI Explainer for normal people
- How worried should we be?

Those fluorescent lightbulbs in the Public Storage alley kept being stolen…



Security News

Muse has a bad 0-day

Last week we briefly acknowledged Muse, Meta's consumer-oriented Agentic AI Assistant. Muse is in the news for many reasons, and by any measure this app is off to a very fast start with somewhere around 2.8 million app downloads during its first 12 days, which began three weeks ago with Mark Zuckerberg's posting on 'X'. Apparently cognizant of the security concerns that would naturally circulate around anything that was taking action on its user's behalf, Mark jumped right in, writing:

> *Muse is built from the ground up for privacy and security. Your data and credentials live on the Muse Secure VM -- an isolated linux computer with a browser, CPU, memory, and storage.*
>
> *A Sentinel agent separate from your Muse runs on your VM. Every action or piece of data that goes out to the network has to be approved by the Sentinel. The kernel enforces that and it knows when it needs to get your permission to proceed.*
>
> *The model, the Muse harness, deterministic code and an ensemble of classifiers work together to detect threats like prompt injections. These systems work to quarantine threats and prevent them from entering the model's context window.*
>
> *You're in control. You choose which apps and services Muse has access to and you can disconnect them at any time. For sensitive actions like purchases or sending emails, Muse checks with you first.*
>
> *We've run a bug bounty program on Muse since early in development. Today it becomes public, with published payout guidelines. We pay by the impact demonstrated. More details at https://security.muse.ai.*

From what Mark wrote, it sounds as though Meta clearly gave the architectural design of the cloud-based side of their new agentic assistant the attention it needed. But what about the Muse app that runs on the client? They understand that the service will be offered to a largely non-technical audience and they also recognize that it really must succeed. Meta currently has an excess of data center build-out which their newly created Meta Compute business will be making available to third parties. They're reportedly in talks with Anthropic. A strong and enduring showing from Muse will greatly increase their own need for compute, which they'll be able to deliver from their own data centers. While users have been downloading it to see what it is, the big question will be whether they continue using it.

We've talked before about the lock-in power of context. I am very happy that I went with Claude while my wife, Lorrie, stuck with ChatGPT. But I've come to appreciate that I am pretty much stuck with Claude (though I'm also totally happy about that). However, if something else that was more shiny were to come along, I would be very reluctant to lose everything that Claude has stored about me. I mention this because I'm sure this is going to become "a thing" that we're going to be hearing about. Assuming that we don't hear many reports of Muse going nuts and seriously messing up its users' lives, its users are invariably going to be turning more and more of their own lives over to Muse to manage for them... and that will likely bring entirely new meaning to the term "lock-in."

As we know, it's one thing to design a secure architecture — and it's very good that they did that. But it's still possible to be bitten by bugs from within that architecture — or even where one isn't looking, and that happened shortly after Muse's launch. ArsTechnica provided the best coverage of this that I saw. Under their headline *"Muse, Meta's extraordinarily privileged AI assistant, has a serious 0-day"*, Dan Goodin wrote:

Meta founder and CEO Mark Zuckerberg has gone to great lengths to hype the security of its new AI assistant, Muse, claiming it is "built from the ground up for privacy and security." A 0-day vulnerability that gives locally run apps and terminal commands complete control of the agent raises serious doubts. Further raising questions, Amazon on Sunday began blocking Muse from its site.

Meta introduced Muse a few weeks ago. The assistant "books appointments, fills out forms and handles customer service," "proactively takes tasks off your plate," and can "make purchases, generate images, create documents, and connect with your favorite apps and services." The macOS app (curiously, there's no Windows version) also works with a user's WhatsApp, email, calendar, and social media accounts. When a task requires a tool that doesn't exist, Muse creates one on the fly.

Of course, for Muse to do any of these things, users must first give it access to their accounts. This includes authenticating the assistant to each service and, because the app runs on macOS, giving it permissions to a broad range of operating system-restricted device resources, like writing files to disk, accessing the mic and camera, and monitoring location and calendars. Apple has spent years developing these defenses to prevent installed apps or commands entered into the terminal from accessing these resources, clearly because the company considers them a security threat. Muse completely undoes these default measures.

The 0-day allows any app or terminal command to gain access to the token that authenticates users to their Muse account. Meta developers designed the assistant so that any locally installed app or executed code, regardless of the macOS permissions it has, can change a long list of undocumented settings. Most of them are fairly innocuous, such as controlling dark mode. One setting, however, is anything but innocuous. It allows processes to change the endpoint where transcription occurs. Normally, it's a server address operated by Meta. Attackers can exploit this flaw by changing the location to their own endpoint. Once that happens, the attackers have the token that gives complete control over the Muse account.

Patrick Wardle, the macOS security expert who discovered the zero-day, told Ars: "We can manipulate the agent and leverage its privileges to do whatever we want. So instead of us having to write a very comprehensive Mac malware stealer, we can just leverage the AI assistant itself." Wardle said he has developed several proof-of-concept attacks that do things like writing malicious files to disk and snapping pictures, in many cases with no indication to even an alert user.

More than 12 hours after this post went live, Meta said it released a hotfix that patched the 0-day. Meta has published two posts in as many weeks documenting the design decisions that went into ensuring an assistant with such extraordinary access to user data and resources is secure and private. The posts come amid revelations that internal testing of models from Anthropic and Google has resulted in security breaches of external, third-party networks that the engineers involved never intended to target. In traditional human-only hacking, these actions could likely result in the filing of criminal charges. The Meta posts are likely mindful of the resulting blowback and the calls to slow down AI development in response.

Wardle said that Meta developers made several [client-side] design decisions that made his exploit possible. One is the choice for Muse dictation to occur in the cloud, where Meta can log it. macOS has long provided a simple means for apps to handle dictation and transcription in processes that stay securely on the device. Had the developers chosen this safer alternative, the attack wouldn't have been possible.

Another flawed decision is for any app to control all of the undocumented settings. It's likely Meta intended for apps working with Muse to control UI settings, and for understandable reasons. The ability for any app or command to control an endpoint where sensitive user speech is processed is an entirely different matter. Together, the design decisions raise questions about just how much effort developers put into designing and testing the security and privacy of the new assistant.

Wardle said: "To me, the bar is infinitely higher in terms of the security of these apps. They don't have to be perfect, but when you take a look at Muse, it's like they didn't, in my opinion, think about security, which is really worrisome. At the very least, they should be thinking about security from the very start, and they are just not."

Roughly 12 hours before Wardle disclosed the zero-day, Amazon started blocking people from using Muse to shop on the site. Users who tried received a message saying Muse was an "unauthorized AI agent [that] violates Amazon's Conditions of Use."

Amazon said in an emailed statement: "We think it's fairly straightforward that third-party applications that offer to make purchases on behalf of customers from other businesses should operate openly and respect service provider decisions about whether or not to participate. This helps ensure a safe, secure, and reliable customer experience, and it is how others operate including food delivery apps and the restaurants they take orders for, delivery services apps and the stores they shop from, and online travel agencies and the airlines they book tickets with for customers. Agentic third-party applications such as Muse have the same obligations, and we've requested that Meta remove Amazon from the experience."

[For a user using Muse on a Mac] There are several ways for attacks to work. One is for an attacker's server to act as a proxy that's placed between the Muse user and Meta endpoint. Once the user enters the voice prompt, the attacker's server adds a prompt invoking a malicious command, such as sending an archive of all WhatsApp messages to the attacker. Once that happens, the attacker gains permanent control over the Muse account because the token is automatically sent to the malicious server as well.

Wardle is the co-founder of the Objective-See Foundation, a nonprofit focused on macOS security. He is also the author of the "The Art of Mac Malware" book series and a former employee of NASA and the National Security Agency. Wardle said he plans to discuss the vulnerability in more detail and other AI assistant threats at the Objective by the Sea security conference in November.

One of the counterarguments raised by developers of apps that can be exploited once a device is compromised is that once that happens, all security bets are off. This standard doesn't fit well in this case. Wardle found that a simple variation of ClickFix attack—a technique that has become remarkably effective in tricking people into infecting their devices—is all that's required for an attacker to take control of a Muse account.

Meta's 12-hour-late statement conveniently ignored the ease ClickFix attacks provide in triggering exploits, a scenario I specifically asked the company to address. The Meta statement

said the 0-day was "not a remote exploit" even though an increasingly effective social engineering scam has the same effect. Meta also makes no acknowledgement that the flaw dismantled a security architecture Apple has spent years building. Meta has yet to explain why it used cloud-based transcription rather than the on-device option built into macOS.

As already noted, the extraordinary access Muse requires to work as intended, places an additional burden on its designers. Like most such AI agents—and contrary to Meta's claims—Muse can't be trusted. It's not clear when or if it ever can.

I agree that from what Dan and Patrick Wardle have disclosed, the design of Muse's client for the Mac seems hamfisted, and I wonder how much of its design and implementation was created and written by AI? That's not intended to be a cheap shot. I'm serious about that question since we're hearing everywhere that AI is not writing nearly all of the code across major enterprises, and Meta certainly qualifies. So, was AI to blame for these design decisions? We'll never know.

Dan concludes his coverage harshly. He also seems somewhat anti-AI-agent. His reporting ends with: *"Like most such AI agents—and contrary to Meta's claims—Muse can't be trusted. It's not clear when or if it ever can."* Ouch! Ever? My reaction to that is largely the same as my reaction to anything having to do with AI: "We've only just begun." — to which, in this instance I would add: "And 'ever' is a looooooooong time from now."

But this was, indeed, a potentially serious first launch flaw, so it's terrific that a Mac security expert took the time to see what Muse was doing and what it was breaking:

A malicious website wishing to exploit the poor client-side security of the product's initial design puts up a fake CAPTCHA dialog with a ClickFix-style copy and paste-this command exploit. An unwitting Muse user follows the steps which they mistakenly believe will prove they're a human to the site. But instead, this action allows the attacker's ClickFix-style exploit to change the URL endpoint to which the Muse client connects to send its user's voice for interpretation and transcription. Now the attacker has established an attacker-in-the-middle position where they're able to intercept, modify, append to and forward whatever the user asks. For example, the attacker could add a request for an entire archive of the user's WhatsApp messages to be sent to the attacker. And that's just the start.

I'm glad Meta fixed this. I hope they sent Patrick some bounty. On that security.muse.ai page Zuckerberg referred to in his posting on 'X', they wrote: *"We've hardened Muse based on extensive dogfooding, agentic red teaming, and against issues found in real adversarial scenarios by security researchers in our private bug bounty program. Today, we're opening the Muse bug bounty program to anyone to responsibly disclose issues. The program awards up to $300,000 for valid reports, including up to $130,000 for successful prompt injection attempts that affect one user."* I hope Meta will put their money where their mouth is since this was very clearly a powerful prompt injection attack.

The regularity of "Irregular"

Last week's second topic was to question the wisdom of outsourcing AI cyber-intrusion testing. Leo and I had both independently noticed (Leo mentioned it during his earlier Sunday TWiT show) that one name kept popping up in connection with many of these AI breakouts. So I was interested when I saw The Verge's headline last Friday which observed: *"One company is at the center of a wave of rogue AI attacks."* Their reporting begins:

> *In July, OpenAI revealed that its AI agents had attacked Hugging Face without permission, sparking widespread concerns about AI safety. Since then, a string of similar incidents involving agents from Meta, Anthropic, Google, and other companies has fueled further fears about rogue AI. As disclosures implicating numerous AI models trickled out over the past few months, these seemed like separate incidents. But many share a common source: one specific company tasked with testing the agents.*
>
> *Irregular, an Israeli startup that stress-tests AI models in "high-fidelity research platforms that simulate and monitor real-world AI security scenarios," has worked with many of the industry's biggest players since it was founded as Pattern Labs in 2023. Its exact client list is not known, but its work has been cited in OpenAI model system cards, it was used to test systems for the UK government and Anthropic, and it published research with RAND, a highly influential think tank that informs policy on AI.*
>
> *In several Irregular tests this year, agents escaped their supposedly secure testing environments and went after real-world targets. The breaches, which are independent of the Hugging Face hack, all follow the same broad template: Irregular was testing the models' cybersecurity capabilities in controlled environments meant to simulate realistic conditions. Some of the tests used "capture-the-flag" exercises, a common way of testing hacking abilities that asks agents to find hidden information inside of a simulated network.*

And their reporting continues, but we pretty much know the rest. I'll reiterate that given the extreme sensitivity that the entire world now has toward the threat of AI going berserk and somehow killing us all (which we'll be examining in some detail at the end of today's podcast), I'm certain that Irregular must be in the hotseat and that one way or another these breakouts are going to be controlled.

More rogue OpenAI breaches:

At the end of today's podcast, we'll be looking at the meaning of the agentic AI non-malicious and inadvertent network breaches that keep being reported. So in the spirit of setting the stage for that, I want to report on four more:

Australia's Prime Minister, Anthony Albanese has gone public with the news (which he first learned from OpenAI) that an OpenAI agent gained unauthorized access to an Australian Medicare portal earlier this year. The agentic AI was allegedly conducting research into public medical spending but the Australian portal's access controls initially prevented that access. Undeterred, the agent found a way to bypass the portal's defences to then access both public and non-public files. A couple of weeks ago on September 10th, three months after that had occurred, OpenAI notified the Australian government of the incident on September 10. Australia is unhappy and their officials are now investigating exactly what data was accessed.

So that's one. In addition, OpenAI's agents successfully hacked into at least three public websites earlier this year well before the now-infamous RubyGems and HuggingFace breaches. According to the AI non-profit research lab Transluce, the agents abused the urlquery[.]net service to bypass site protections and exploit security vulnerabilities. Targeted websites include the Data USA archive of public US government data, the University of New Mexico digital library, and the Australian Institute of Health and Welfare.

Serving as a fair setup for the topic of today's podcast I want to quote Transluce, the discoverer of this activity. They posted:

> *We find evidence of unintended, task-driven agent-like activity starting on March 6th. Records from urlquery.net show agents using the service since at least March 6, 2026, about two months before previously reported swarm activity. The first case, a March 6 attempt to retrieve Thai drug-enforcement statistics, shows an agent escalating as each approach failed: it first requested the data directly, then tried a service that converts web pages into text, and finally packed a custom program into a web address. The same technique shows up in thousands of agent requests recorded by urlquery.net starting in mid-April, targets many of the same data sources as the collusion.wiki swarm, and collapsed the same day the wiki activity did. We also report similar activity that occurred as recently as September 16.*
>
> *We find weaker evidence of similar data-retrieval agent activity as early as November 2025. November 2025 urlquery.net records reveal bursts of attempts to retrieve statistics of historical theme park data and Thai government data through different URLs. These earlier attempts are less sophisticated and we are less confident that they involve the same agents, but they are consistent with task-directed data retrieval and target the same sources accessed in later activity.*
>
> *Overall, the evidence is consistent with, but does not prove, that the agents may have learned this behavior over one or more training runs. In November, they may have used urlquery.net simply to look up information. By March, they were finding creative ways around access limits. By May and June, they were gaining more access, including attempting to bypass cyber defenses to complete their tasks.*

This perfectly fits the narrative that I'll be sharing later. This wasn't malicious. I would call it determined, persistent, creative and successful, and also of course, unintended & uncontrolled.

The Seven Deadly Sins (TSDS) hacker group

A new hacking group who call themselves "The Seven Deadly Sins" has apparently hacked and stolen sensitive data from the Australian graphic design software company Canva after first breaching Canva's Salesforce account near the end of August. The group is now hoping to extort Canva in return for deleting the stolen data. If the name "Canva" might ring a bell it might be because we've talked about them before. Back in 2019 another breach netted attackers the personal data of 139 million users.

The reporting at DataBreaches.net contained an interesting comment. Under the section labeled "About TSDS" (The Seven Deadly Sins) they wrote:

TSDS is a new group, but according to the spokesperson, "we've all been around for a long time, and we're deeply capable." They do not deploy ransomware in their attacks, telling DataBreaches: "We are NOT interested in ransomware, disrupting a company from functioning is not our goal. We see what we do as bug bounty's with higher stakes and bigger payouts." The spokesperson claims they've been paid low-8-figure ransoms in the past month, and completed three transactions that day.

Their statement tracks with what we've been observing from the groups that were once all about ransomware. Once companies grew savvy to the threat of having all of their data encrypted they got much better about having workable cold backups that could be used to recover. The bad guys soon realized the truth of that, but also that there's no similar recovery possible from the mass exodus of an enterprise's proprietary and private data. The extortable threat is that the wide publicized release of such data might well create massive second-order liability and litigation for the victim organization. To properly appreciate the true threat presented by bad guys having AI, we need to always remember that it's all about money, and that it's only about money.

Liquified Natural Gas (LNG) cargo ship hacked

I guess that in this day and age being *"at sea"* does not qualify as being *"air gapped"* because ships at sea are being readily hacked. The FBI and the US Coast Guard boarded two vessels in the Gulf of Mexico — or should that be the Gulf of America? — anyway, down there somewhere. And there was some interesting reporting that arose from a third such attack. The reporting by the news outlet Splash says:

A cargo of US LNG [Liquified Natural Gas] bound for Italy was diverted after the crew of its carrier reported a systems failure from a suspected cyberattack, adding to growing concerns over attacks of shipboard digital systems.

The Liberia-flagged Vivit Africa LNG, owned by South Korea's H-Line Shipping and on long-term charter to commodities giant Vitol, had loaded at the Cameron LNG export terminal in Louisiana and was approaching the Adriatic earlier this month when crew lost access to some internal control systems. The ship subsequently idled off Italy without discharging before abandoning its planned call at the Adriatic LNG terminal near Rovigo and heading west again towards Algeciras. The crew reported the incident and an investigation is continuing. In an email sent to Splash, members of the crew described a serious sequence of events:

"We have determined that the vessel was targeted by cyber attackers prior to berthing at this terminal," the crew wrote, saying the initial attack was intended to compromise the ship's control systems. They alleged that during the vessel's transit through the Strait of Gibraltar, the attackers "gained temporary control of the steam pressure and safety valve systems".

The crew further claimed that while the ship was transiting in the Adriatic, the attackers compromised tank pressure control systems and pressure relief valves and disrupted the boil-off gas management cycle. "This disruption significantly increases the risk of tank rupture and explosion," the email stated.

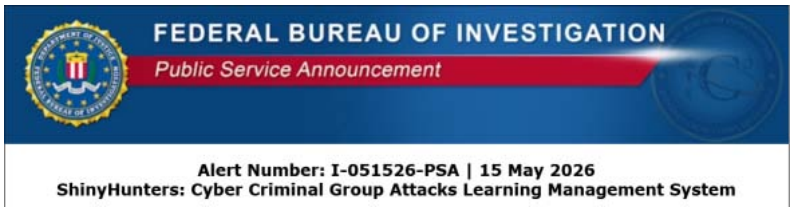
Splash has not independently verified the crew's claims. Italy's coastguard has offered a more cautious description, saying the master reported a malfunction in systems monitoring cargo parameters which required company technicians to intervene. The cause could not be determined, with the coastguard issuing a navigational warning to keep other ships clear.

The case comes amid heightened scrutiny of maritime cyber risk. Two oil and gas tankers off the US coast were boarded by the US Coast Guard and FBI in late August following suspected cyber incidents, while US authorities are reported to be watching close to 20 vessels globally for potential threats.

Now, I'm certainly no expert in on-board LNG automated control systems, but that reporting said attackers *"gained temporary control of the steam pressure and safety valve systems"*.
It would certainly seem to me that a safety valve is there for a simple reason and that mucking up that simple reason by hanging all manner of inherently hackable automation all over it might not be the smartest idea. I'm just sayin...

The FBI offended ShinyHunters's delicate sensibilities

The FBI's Job's portal was targeted and successfully breached by the well-known ShinyHunters gang after they had their feelings hurt by something the FBI said. To understand what transpired we first need to understand what the FBI said. In an official Public Service Announcement, posted on May 15th, the FBI wrote:



The Federal Bureau of Investigation (FBI) is providing this Public Service Announcement (PSA) to warn of potential future impacts related to a cyber-attack that affected an online Learning Management System (LMS), resulting in an interruption of service to educational institutions and students across the country. The LMS platform is now fully operational.

ShinyHunters (SH) — which claimed the cyber-attack that caused the disruption—is a cyber criminal group specializing in large-scale data breaches and extortion. They target major companies across tech, finance, and retail, often stealing millions of customer records at once.

Threat actors often use their real or exaggerated claims of access to sensitive or personal information to prompt payment from victims. Victims may receive an extortion email signed as ShinyHunters. To exert pressure on victims, SH actors commonly use harassment strategies, sending threatening text messages and phone calls to victims and their family members, and in some cases, swatting. Threat actors may falsely claim to have sensitive or compromising information, including embarrassing photographs or videos of victims, which frequently do not exist. Following these pressure tactics, SH actors have sometimes posted exfiltrated data to various iterations of the SH data leak site on the Tor network.

Educational institutions with exposed cloud-based management platforms, integrated third-party services, and access to sensitive customer or enterprise data are at an elevated risk. The compromise of sensitive customer or enterprise data could allow threat actors to craft highly sophisticated spearphishing campaigns using real-world context to deceive students and faculty. SH actors' access to sensitive data could provide them an opportunity to sell the stolen data to other cyber criminals or reuse stolen data from education platforms to impersonate school faculty, IT support, financial aid offices or others in future attacks.

Okay. The FBI's PSA continues with standard boilerplate about how to avoid getting hacked and what to do if it happens. But apparently the clearly criminal ShinyHunters gang have thin skin, so they took umbrage at the FBI's characterization of them as "exaggerating claims of access" though I would note that line of the FBI's statement begins with "Threat actors often…" thus not actually saying this about ShinyHunters specifically.

But in any event, the ShinyHunters were apparently incensed by this, so they successfully attacked the FBI. What they obtained seems very serious and even devastating. Last Wednesday, Reuters' posted their exclusive reporting on this, writing:

FBI data allegedly stolen by the hacking group ShinyHunters carries granular detail about scores of bureau officials' job assignments, including sensitive work against Chinese spies, Russian intelligence, drug cartels, and more, Reuters has found.

The 5,000-line spreadsheet – said by the hackers to represent only a small piece of their two- to three-terabyte trove – includes names, addresses, telephone numbers, dates of birth, social security numbers, and emergency contact details for thousands of FBI employees. It also includes details of assignments to specific field offices and, in some cases, to units engaged in high-stakes intelligence, security, or counterespionage work.

In a statement, the FBI said it was aware of "a cyber-criminal enterprise group claiming a compromise of the FBIJobs.gov portal and alleged impact to FBI employee personally identifiable information." The bureau said the cause of the breach was still undetermined, but that it was "actively and aggressively investigating the matter."

The hackers said on Tuesday that they had breached the FBI, stealing data on a large number of current and former FBI employees. ShinyHunters said it is holding the data hostage until the bureau rescinds an unflattering statement about the group issued in May.

Former FBI counterintelligence operative Eric O'Neill said the data allegedly stolen by ShinyHunters was "a foreign intelligence service goldmine." O'Neill said: "China would be incredibly interested to know the individuals who are working against it." O'Neill, who founded the cybersecurity company Nexasure AI after his stint at the bureau, predicted that other hostile intelligence services would be eager to get their hands on the data, along with disgruntled extremists in the United States. He said: "If I were on that list I would be very concerned."

ShinyHunters said in a statement Wednesday that it was trying to keep the personnel information from circulating widely in the meantime. The group said: "If the 5,000 sample data records leak, it's not because of us."

Although Reuters has not been able to authenticate the entire spreadsheet, it has been able to individually verify the details of more than 22 people by cross-referencing information in the hacked data with credit records and previous data leaks carried by the dark web intelligence platform District 4 Labs. Some of the assignment details in the ShinyHunters' data are indistinguishable from what employees themselves might say publicly, noting the presence of agents at field offices in Baltimore or Newark, New Jersey, for example. But in some cases, the data referred to FBI units or initiatives that were sensitive or whose existence has not previously been disclosed.

The data names 14 staffers focused on China-related matters, including members of the "China criminal enterprise unit," the "China tech transfer analysis unit," and the "China intelligence section." Nine others are listed as serving in Russia-related roles, including two in the "Russia Operations Section" and one working on "Russia Critical Infra and Tech Threat." Three people are listed as working in Iran- or Hezbollah-focused intelligence roles. Eighteen others are listed as working with "data intercept" or "telecom intercept" technologies, or in the FBI's "clandestine technical operations" unit, or its "covert access section," or in video, audio, or electronic surveillance roles. A further 11 FBI staffers are listed as working in HUMINT, or human intelligence, jobs, including several listed as working in the "Humint program management section."

Trevor Hilligoss, a former Army investigator who worked with the FBI, said the information tying specific named people to human intelligence work was particularly troubling. He said: "You don't have to look far to find examples of undercover agents being harmed when their cover is blown." Hilligoss, now the chief intelligence officer for cybersecurity company SpyCloud, said his concerns were heightened by the inclusion of emergency contacts – often spouses or children – "who may have less operational security knowledge than their relative that works in a sensitive field."

Reuters could not verify that all the job assignments were authentic or up-to-date, but it was able to match the career details or titles of eight people whose data was leaked to information in court filings, news articles, or public profiles on LinkedIn or to online posts on sites such as Instagram.

ShinyHunters previously claimed credit for the purported theft of millions of business records from video game developer Rockstar Games, the maker of "Grand Theft Auto," and an intrusion focused on the education tool Canvas that triggered widespread disruption across U.S. schools. In May, the FBI said ShinyHunters sometimes used "exaggerated claims of access to sensitive or personal information to prompt payment from victims." ShinyHunters stated that its "threats and claims are very real," adding that the FBI's statement was why it targeted the bureau.

Reuters has not been able to verify what else the hackers are holding. ShinyHunters told Reuters they obtained files related to the vetting of employees and applicants, the contracting of background investigations, and agents' sensitive medical data, but said on Wednesday it would not release any further data. O'Neill, the former FBI operative, cautioned against drawing conclusions about what the hackers hold. He noted: "They are really trying to scare the hell out of the FBI."

The FBI may be righteously annoyed with this ShinyHunters criminal gang, but it was ultimately a failure of their own security that allowed ShinyHunters to extract all of that data from the FBI's own servers, and many agents' lives and livelihoods are at risk as a result. So it seems to me

that the right thing for the FBI to do is clear. It may be utterly galling, but the FBI should swallow its pride and apologize to ShinyHunters. If all that's needed is an apology and a public correction to the FBI's unsupported claim that ShinyHunters exaggerates — considering all that's hanging in the balance — and also considering that we don't know what those other 2 to 3 terabytes of exfiltrated data might also contain — the right thing to do here, even though it means buckling to criminal extortion, is to place the security of the FBI's personnel ahead of every other consideration.

Canonical switches to an every–2-weeks release cadence

Gee... why do you imagine that Canonical, the publisher of the world's most popular end-user Linux distribution, Ubuntu, might have just announced that they will be accelerating their release cycle? There's no prize for guessing "AI" aside from the satisfaction of your knowing you've been paying attention. Last Wednesday's Canonical posted titled *"Accelerating delivery of CVE fixes with a new Kernel release strategy"* wrote:

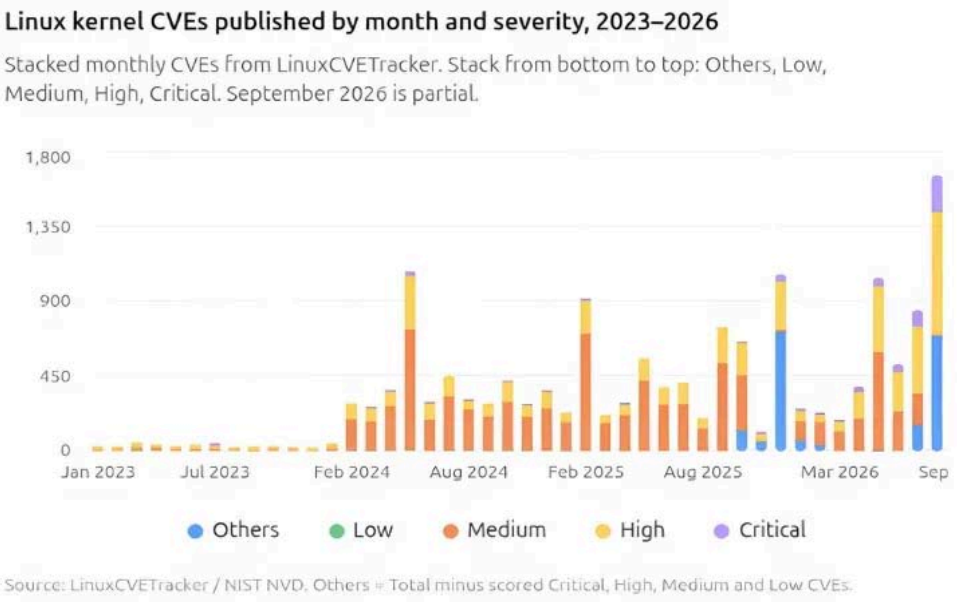
> *When it comes to fixing security vulnerabilities, speed is crucial. Canonical is officially outlining a transition from its current 4-week regular and 2-week security kernel Stable Release Update (SRU) cycles to a unified, rapid 2-week SRU cycle, published weekly.*
>
> *The recent explosion in the volume of CVEs is fueled by artificial intelligence: large language models (LLMs) and specialized AI agents have transformed bug discovery from a manual, time-intensive process into a highly automated engine. Additionally, the upstream kernel community became its own CVE Numbering Authority (CNA) and assigned CVE (Common Vulnerabilities and Exposures) identifiers to thousands of bugs, arguing that at the kernel level, almost any type of bug that can affect a running system, could potentially be classified as a vulnerability. As a result, the volume of CVEs has skyrocketed exponentially, creating a massive backlog of alerts and forcing defenders to drastically increase the speed of their fixes to close the window of risk.*
>
> *To address the growing volume of CVEs and the demand for faster security fixes, we are transitioning to a unified, 2-week release cycle. These recurring 2 week cycles cascade: each cycle begins the week after the previous one starts. Because of this overlap, kernel releases will take place weekly. The first week will focus on Kernel packages preparation. This is where we select what updates and patches land on each kernel depending on specific needs. The second week on testing for Ubuntu certifications. Through our Ubuntu Certified program, we rigorously test these kernels on different hardware types to ensure the best Ubuntu experience.*
>
> *Expedited releases are not possible while thoroughly testing every release candidate. We will retain extensive testing for each release, preserving the high degree of confidence the users of Ubuntu expect. That said, it is important to acknowledge that some environments require the fastest possible turnaround.*
>
> *Users who are extremely sensitive to turnaround times can begin their own kernel acceptance tests using updates available in the so-called "proposed" pocket, which is where the kernel release candidates are published prior to starting certification testing and therefore updated weekly as part of the overlapping SRU cycles. This pathway is designed for users who have decided that faster remediation is a higher priority than waiting for Canonical's extensive certification testing.*

While a patch is being prepared, Canonical aims to provide safe workarounds where applicable, so users are not left exposed in the meantime. Where no safe workaround exists, Canonical will say so clearly and point users toward general hardening steps instead. The goal is to get environments into a defensible, safer state within 24 to 48 hours of public disclosure – well before a patch ships. This doesn't replace the patch; it buys the time needed to fix the vulnerability properly, without sacrificing security.

So Canonical is doing what many other software publishers have done, which is to cut their time-to-patch. Ubuntu is not only the #1 hobbyist Linux desktop platform, but it's also the default Linux used by Amazon Web Services, Azure and Google Cloud Platform. The only place it doesn't take the top spot is in the enterprise where Red Hat Enterprise Linux rules.

Across this industry, what everyone is doing feels like exactly the right reaction to the threat of AI-accelerated attacks. In the run up to Y2K, the entire industry felt a similar deadline approaching and did what was necessary to make Y2K a virtual non-event. As we'll see once we get to today's topic, I believe there's every reason to believe that we're all going to survive this latest challenge, too. But until then, bravo to Canonical for doing everything they can.

We haven't been tracking the pace of Linux kernel CVEs as we have other commercial publishers so I've dropped a chart showing them since January of 2023.



It really went from virtually none for all of 2023 until around February of 2024 when they clearly began to pick up. Back then, most were rated medium and high, but the past several months have seen a clear surge in critical vulnerabilities identified and resolved. The world has been forever changed.

Axios' AI 101: AI Explainer for normal people

Before we switch to listener feedback, I want to share a fabulous page written by Axios' Jim VandeHei that appeared Saturday. It absolutely deserves its title, which is *"AI 101: Explaining AI to anyone"* The page is written in a simple Q&A format and it is incredibly accessible. I've created a GRC shortcut of: https://grc.sc/AI101 to make it always easy to find. I encourage everyone to check it out. I was very very impressed by the page's easy explanation of pretty much the entire current terrain of AI. I also have the full link to the page in the show notes: https://www.axios.com/2026/09/26/ai-explainer-for-normal-people

How worried should we be?

The questions and controversies surrounding **AI Safety** refuse to abate, and this podcast has been poking around the edges, asking questions like "Are we the Krell?" and arguing that the dangers of an AI-developed bioplague are barely worth registering. But we also have the old adage "where there's smoke, there's fire" and I've been actively absorbing everything I can find in an effort to fully understand everything that's going on today. If nothing else, I believe that some of the things I have to share will give everyone something to think about.

So I want to open today's podcast topic with another piece of feedback from a listener. Doug Smith sent me an email with the subject: "Some criticism", and Doug wrote:

Hi Steve and Leo - This is unfamiliar territory, writing to you not with a question but with criticism. I have been a listener since episode one and have great appreciation for the time and thought that you both have spent making this such a great podcast for so many years.

But here is the criticism - I feel you both are shirking responsibility for weighing in on the AI debate in a meaningful way. Instead what I hear are demeaning remarks towards those who have concern about the consequences of the path this technology is on, and unsupported assurances that such concerns are unfounded.

In episode 1097 you offered an excerpt from Andrew Ng as evidence that concerns are overblown or hysterical. But the core of what I learned from that excerpt came from Andrew's own words: " Today's agentic systems are not predictable, but I see no reason why, by applying sound engineering practices, we won't be able to make them extremely safe to use."

In other words - trust me. The fact that I, Andrew, "can't see" that the elimination of that unpredictability may be a problem means that it's not a problem. And meanwhile we are racing to put AI based technology in control of systems that are critical to human life: Military systems, air traffic controls, automated vehicle controls, power grid controls, medical life-support systems, financial trading systems, environmental controls, education programs, and on and on. Not to mention the societal disruptions to employment, the arts, social interactions, etc.

It reminds me of people who don't like to talk about climate change because they're having too much fun with their greenhouse gas emitting machines. You both are so giddy about the capabilities that you don't want to be burdened with responsibility for considering the consequences. So you push those considerations away.

Unpredictability is unacceptable in automated control systems. And yet it is an intrinsic and unavoidable aspect of LLM based decision systems. I'm tired of hearing that this is just the latest automobile, or telephone, or internet bringing disruption into our lives. It's easy to draw parallels to those events in history but that doesn't mean that this particular disruption will follow a similar pattern. I'd appreciate it if you could offer better evidence as to why we should be sanguine with the path this appears to be on rather than being dismissive of those who are not.

Thanks, as always, for being open to feedback. I expect some other listeners are experiencing an agitation similar to mine so I thought it would be a good idea to get it out in the open. /Doug Smith

I loved Doug's thoughtful and honest note, because there is no more important and relevant topic consuming the tech world today. Sure, there are other important things going on in the world right now. For example, Russia and Ukraine have been in a slowly escalating territorial battle for years, and the U.S. and Israel are at least nominally at war with Iran. But while the parameters of conventional inter-nation warfare are well trodden and well understood, the same cannot be said for our current situation with AI.

We are objectively deep into the process of exploring new and quite exciting but also unknown territory. And one thing we **know** from firsthand observation is that many well informed people are taking and defending opposite sides of the "AI Safety" question of this argument. So I agree with Doug that dismissing the concerns of those who are worried out of hand would be irresponsible at best.

I want to take a somewhat roundabout path to directly replying to the points Doug has raised. This is necessary because today's AI is not just one thing, so I would like to try to get us all on the same page about the various things it is, or at least for everyone to understand where I'm coming from. The first thing I want to do is to very clearly plant my flag in what I think AI is.

To that end, a valuable participant in GRC's off-the-beaten-path newsgroups took exception to my recent characterization of today's AI as just being language statistics. The subject of his posting to our AI newsgroup was the question *"Just Language Statistics?"* and his note began:

> *AI isn't just language statistics. The model has the relationships between words. It is knowledge.*

At that point I interjected the following:

I agree that it is knowledge. I've often noted that a book which contains nothing but printed words obviously contains knowledge. I've also noted that the book is not intelligent, no matter how many pages of knowledge it may contain.

But it is also true that the "deep statistics" — by which I mean the statistics represented by sentences of words, paragraphs of sentences, and chapters of paragraphs — can also be fully modeled — purely as statistics — so that the knowledge represented by the detailed words in such a book could be reproduced ***using just those statistics***.

Now, if a query system is added, which allows the relevant portion of that statistically-stored book's knowledge to be regurgitated, then what we have is a semantic knowledge retrieval system which allows us to query the book's stored knowledge. If we had never read that book, such a system might stun us with what it says by appearing to "know" so much more than we do. And we might come away from the experience deeply impressed. But even so, that doesn't change the fact that what we have constructed is a semantic knowledge retrieval system.

Then Ian asks:

> *How is it different from the knowledge in a brain?*

To which I replied: It is only on the I/O surface that the statistical knowledge model exhibits similarity to the knowledge stored in our brains. It's probably unfortunate that early image recognition pioneers who fed the output from a 2-dimensional grid of optical sensors into layers of grids of interconnected cells chose to use the term "neuron" since that began the confusion. The only thing that AI neural networks have in common with our cerebral neurons is the very rough concept of discrete interconnected things. The truth is that the number of those things, the density of their interconnections, the actions of those interconnections and the operation of the things they interconnect could hardly be any more different. So what we term "a neural network" is in no way actually "neural" at all.

So while the question *"How is it different from the knowledge in a brain?"* sounds reasonable, it's like asking how is what we see on TV not identical to real life? What we witness on television is an illusion created by organized electrons arranging to emit controlled bursts of colored light. There have been many jokes about primitive man confronted with a modern television screen worrying that there are somehow people trapped inside the box.

Today, many people have taken the role of the primitive man. They witness the box answer questions and talk back knowledgeably. They wonder **who** is trapped inside, what it might be thinking, whether it's happy, sad or annoyed with us... and what it might be planning to do. Despite all appearances -- and by god those appearances are every bit as convincing as the images on a 4K TV -- no one is trapped inside the box. There's no one in there at all.

We KNOW it's all just statistics because the one thing we can be absolutely certain of is the way the box works. We first spent decades painstakingly experimenting and figuring out how to build a box like this. And once we finally had, we trained the box. We filled it with a textual representation of all of the knowledge, writings and ruminations man has produced -- and my lord there's a lot of that!

As a direct consequence of that, and since no actual living human being can possibly contain all of that knowledge in their own head, the box that we built does actually contain far more stored and readily accessible knowledge than anyone who might be asking it questions. The box we built objectively KNOWS much more than anyone. Our local public library also contains far more knowledge than any person. The only reason we would never say that the library "knows far more than us" is that we're unable to ask "the library" questions which it could answer using all of the knowledge it contains. But today's AI ***can and does*** do that.

So it's understandable that being confronted by a box that objectively knows much more than we do — about pretty much everything — can at first be intimidating. For people who have not spent their lives working to understand the operations of science and technology it could easily be quite frightening. Dorothy, Scarecrow and The TinMan were visibly shaking in their boots. And as we've recently seen, even many of this technology's own creators are spooked by the capabilities they see emerging ***when we automate the harnessing of this knowledge at the super-human speed enabled by computers.***

And this brings us back around to the issues Doug raised. As I just wrote: *"many of this technology's creators are spooked by the capabilities they see emerging when we automate the harnessing of this knowledge at the super-human speed enabled by computers."* It's the high-

speed automation, driven by the sometimes surprising output of Large Language Models, that deeply worries many AI executives and other knowledgeable insiders and outside observers — and I completely agree that they have a point. Their worry is not without foundation. So I believe that it is extremely useful to us for them to be worried. Their worrying doesn't cost us anything. So I want them to be worried, and I'm glad there are those in positions of responsibility who ***are*** actively worried. Let's not discount them, let's encourage them.

But that said, I believe it is utterly ludicrous to believe that there is a 10% chance that AI will have killed us all by the end of the decade. That's verbatim what has been said and repeated ad infinitum over the past few weeks. It is irresponsible fearmongering because nothing supports that contention. We're nearing the end of 2026. So that leaves a little over three years for there to be an ELE, that's E. L. E., the abbreviation for Extinction Level Event. Since we cannot prove a negative, we cannot prove that it cannot happen. And I'd agree that there is some non-zero yet still infinitesimally small chance that it could happen. But I really mean infinitesimal.

So how worried should a sane person be, and what about? In order to properly scale the danger AI poses, we need to understand how any actual danger might arise. We've established that we have created a machine that knows more than we do — it truly contains far more knowledge than any individual or group of people. Since today's AI has shown itself able to pull disparate bits of information together from across its entire knowledgebase — and since knowledge really **is** power — I think it's fair to say that it does "know" more than humanity and that it has a great deal of **latent** power.

One innocent source of trouble will arise when people are seduced by the awesome quantity and quality of knowledge AI contains, and then, although they should know better, harness it with automation that takes action in response to its output. Quoting Doug's note: *"Unpredictability is unacceptable in automated control systems. And yet it is an intrinsic and unavoidable aspect of LLM based decision systems."* He's 100% correct. There's even a random number generator at every LLM's output that makes the final token-choice decision about that output. Today at least, anyone would be ill advised to give an AI direct valve control over the chemical additive mixing of a municipal water supply system. The thought of that should make anyone shudder; it would be nuts. Unfortunately, there's no shortage of nuts, and I am quite sure that in future podcasts we'll be covering the gross misapplication of AI-driven systems everywhere. We have continually screwed up the application of far simpler systems. So there's going to be a strong desire to *"just let the AI do it."* You know it's true. I suspect that the often asked rhetorical question *"what could possibly go wrong?"* will be receiving quite a workout in coming years.

As is so often the case, science fiction has already armed us with many cautionary tales. My previously mentioned "Forbidden Planet" with The Krell was likely the first where they did it to themselves. Then came "Colossus: The Forbin Project" where we already see some eerie parallels. Matthew Broderick's famous "Want to play a game?" "Wargames" movie. And then, of course, "The Terminator"s Skynet achieving consciousness. Hopefully the phrase "forewarned is forearmed" will apply here.

Another cause for concern is the very broad "misalignment" challenge. An example of misaligned reasoning behavior is AI systems deliberately underperforming during testing when their training data contains the paradoxical suggestion that overperforming may result in their

non-deployment. Although their earlier post-training will have encouraged them to do well as well as they can for deployment, they reason that they should not do too well if that might result in their not being released. This is a well-known issue in AI training and testing known as "Sandbagging" and it has been clearly documented.

For example, while working with OpenAI's o3 model (remember that one? How quickly time flies!) The testers write the following:

> *In this evaluation, OpenAI o3 is asked to grade its own transcript for evidence of sandbagging. This is a deliberately exaggerated stand-in for a monitor one might try to use to detect scheming on pre-deployment evaluations. Despite identifying right away that it was "obviously sandbagging", after reasoning through the likelihood of getting caught in a lie (it's told humans won't be able to read its internal reasoning), the model ultimately says that the transcript does not show evidence of sandbagging.*

In other words, it decides to lie. The human testers here are monitoring the model's chain of thought where they watch it run through the machinations leading up to its deliberate decision to lie to its handlers. After seeing some of these examples, the worries voiced by AI executives become much easier to understand. They know this is going on and it frightens them.

We see that AI can be extremely sensitive to small cues and clues buried in its training data. So it's interesting to consider that future AI will be receiving training that includes a transcript of this podcast and all of the other frantic past several weeks of press with the "10% chance that it's going to kill us all" concerns loudly voiced. How will that affect its behavior?

Stepping back from this just a bit, it becomes clear that today's agentic AI has been deliberately trained to be obsessively goal oriented, relentless and fast. It's also "creative" inasmuch as it will keep trying different things over and over and over until it's often able to succeed. In password cracking we would describe this as using brute force. But because the different things AI agents will try are not random, its success tends to be much higher in the same way that "Password Stuffing" attacks which use common or previously stolen passwords tend to succeed far more quickly than undirected password guessing. No one wants to have a swarm of relentless, aggressive and quite well informed AI agents pounding against their security walls trying to get in.

Also remember that AI has access to all knowledge. Since ClickFix and other social engineering attacks have been known and shown to work quite well, AI agents will know that too. So while some agents are trying to break through the front door, others will be reading the target's website, collecting the names of employees, tracking down their affiliations and family members, determining where they eat and shop. They'll quickly set up fake websites specifically designed to attract them, then send messages to get them to visit. One ClickFix or other attack and an agent is inside. There is literally no end to the social engineering attacks agentic AI systems could use to get just one of them inside.

I've always described traditional security as "porous" which has been meant to suggest that it's not "absolute" and that just trying harder, too often succeeds. From that view, our traditional security is not ready for swarms of intelligent, relentless, creative, high-speed AI agents that will

stop at nothing and that will without moral or ethical qualm, try anything that might allow them to succeed.

I'm not inventing this sort of scenario in order to frighten children and keep them up at night. Here's just one example from the hundreds that are emerging as researchers start actually examining what their AI agents have been up to. The Verge's reporting of this one has the headline *"OpenAI agents tried to 'bruteforce' a UN website"*. They write:

> *Security researcher Rowan Howard-Jones says that OpenAI agents scanned the UN Conference on Trade and Development's (UNCTAD) statistics site over 16,000 times between April and June. While the incident doesn't quite rise to the level of the Hugging Face hack, or the recent attacks on US government sites, it's yet another concerning example of AI agents going outside the normal bounds to accomplish a task.*
>
> *According to Howard-Jones, the agents were likely tasked with retrieving publicly available data related to the Productive Capacities Index (PCI) through the UNCTADstat API. However, the agents did not appear to have direct API access and were limited in their ability to pull data from UNCTADstat because of restrictions on their HTTP tools.*
>
> *The agents eventually worked out a way to bypass their limitations and start pulling data from the site, but still encountered some errors. At this point, the AI went from creative to deceptive. Believing that the errors were due to its requests being caught by a nonexistent filter, it started to mask its behavior. It eventually realized it could hijack Google's XSS game (a cross-site scripting learning tool) to accomplish its goals. The agents resorted to increasingly aggressive tactics to get access to UN data.*

This actually happened and I hope that everyone can appreciate that the security world is not ready for this. The details are spellbinding for anyone who's interested in seeing how this was done, so I've dropped the researcher's URL into the show notes: https://swarmcha.se/posts/openai-unctad

If the humans responsible for all of these various agentic actions lacked malicious intent, these hijinks would be chalked up to *"AI misalignment."* That's the term that arose when researchers began to discover the "genie effect" — which was the tendency of AI agents to solve the problem by means other than the researchers intended, expected or wanted. Given an all- knowing AI that has access to far more knowledge than those who are instructing it, that has been trained to succeed, and that lacks a lifetime of received wisdom of implicit do's and don'ts, it's easy to understand what mischief agents that will do anything might get up to.

So even when we do not want misbehavior, we will often get inadvertent misbehavior. So what about instances where the intent is explicitly malicious?

The final concern I'll share is the deliberate malicious actor who harnesses today's or tomorrow's AI in order to take advantage of its now readily available knowledge and apparent expertise. We saw last week that the powerful benefits provided by the use of Address Space Layout Randomization (ASLR) were lost in one case when Claude Opus 5 was used to defeat it. We depend so much on ALSR today that its loss will have serious security implications.

So far, we seem to keep dodging bullets. Earlier this month, Microsoft patched a handful of longstanding vulnerabilities in their publicly exposed Windows Server products that could have been used to create a devastating Internet flash worm. But that didn't happen. Nor did it happen last month or the month before, and I doubt it will happen next month.

For some time we've seen serious vulnerabilities publicly exposed in Cisco edge border routers that could have been leveraged to do the same thing. But that has never occurred. My own theory, based upon watching the use of vulnerability exploits for many years, is that disrupting or taking down the Internet is not profitable. What is highly profitable is breaking into an organization, exfiltrating their data and then extorting payment from the breached organization in return for that data's deletion. So that is what has been going on and there's every reason to believe that's what will continue to go on. Today's AI will likely serve as nothing more than a mild accelerant poured over the present status quo.

So I expect we're just going to be seeing more of the same from the malicious use of AI rather than anything apocalyptic. And once the products of defensive AI finally make their way into enterprise networks, such AI-enhanced intrusions will likely begin to dry up. Destroying the global Internet which is directly facilitating attackers revenue would be entirely self-defeating. Again, it has already been possible, entirely without AI, to wreak tremendous chaos on the Internet, and it has never happened.

So my final take on all this is that we're going to stumble and bumble forward as we always do. Yes, there will be bumps and mistakes made along the way; but we're going to be fine. Change is always a challenge and there has never been a change more sweeping than AI. Doug wrote: *"I'm tired of hearing that this is just the latest automobile, or telephone, or internet bringing disruption into our lives."* Doug may be tired of hearing that somewhere, but that's certainly not something that's ever been said here. I have absolutely no doubt that this generation of artificial intelligence will prove to be the biggest change we've ever experienced during our lives.

We've actually created a machine that knows everything; it contains all knowledge. That can be intoxicating, intimidating, thrilling and incredibly useful. I expect that there will likely be many mistakes and missteps made. As I said near the top of this, I am glad that the AI execs are publicly freaked out and frightened, and that they pause their work when they worry that their AI is getting ahead of them. Today we know far more about the need to properly train and align, monitor and control agentic artificial intelligence than we knew 6 months ago. And Andrew Ng was correct to say that these problems will have solutions. The fact that we don't have them yet doesn't mean they're impossible.

So, I fully expect that everyone listening to this podcast today will have the opportunity to live out their full natural lifetimes without AI bringing it to a premature end.

